Claude Code の Dev Container を ISMS で運用する流れ

（氏名）

2026 年 10 月 4 日

この資料の目的

Dev Container の運用を、 ISMS の 4 つの段階に沿って整理する

前回の資料は 10 のリスクで管理策を評価した [1]

Claude Code の Dev Container

AI がコードを書く道具を隔離して動かす環境

実機では検証していない

- 4 つの管理策を評価
- 6 つは低減できる
- 4 つは低減できない
- 10 のぜい弱性が残る

ISMS では 3 つの承認を得て 4 つの段階を回す [2]

ISMS

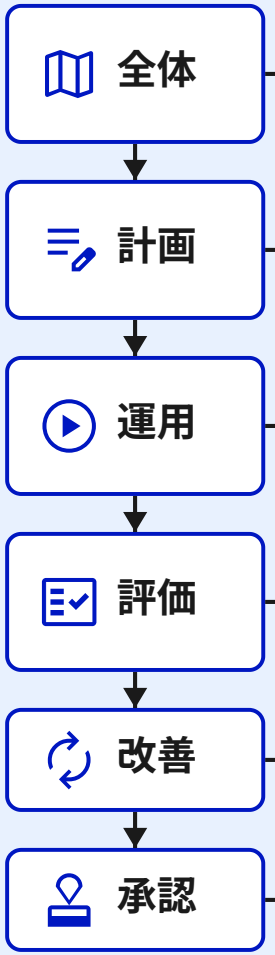
情報セキュリティを組織で管理する仕組み

現行の規格の本文とは突き合わせていない

- **承認** 3 つを得て始める
- **計画** リスク対応を決める
- **運用** 3 つの場面で実行する
- **評価** 記録と監査で確かめる
- **改善** 見直して計画に戻す

まとめ

Dev Container は、 3 つの承認を得て ISMS の 4 つの段階で運用する



4 つの段階は、計画、運用、評価、改善の順に回り、承認で始まる

- 段階ごとの担当と記録

計画では、 10 のリスクごとにリスク対応と担当を決める

- 基盤の担当が強制する設定
- 附属書 A との比較
- 残留リスク

承認を得たら、利用開始、日々の利用、事故の 3 つの場面で運用する

- 利用開始の流れ
- 日々の利用の決まり
- 事故のときの流れ

報告と日々の記録は、内部監査で決まりどおりかを評価する

- 評価に残る課題

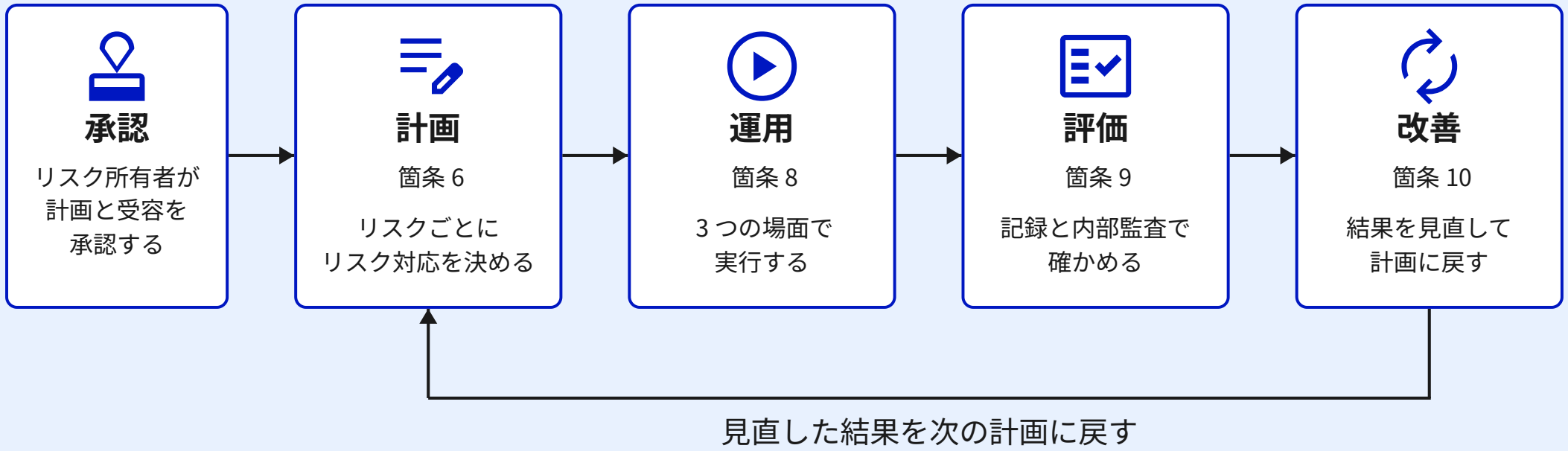
課題と評価の結果は、マネジメントレビューで見直して計画に戻す

計画を運用に移すには、 3 つの承認が要る

運用フローの全体像

4 つの段階は、計画、運用、評価、改善の順に回り、承認で始まる

4 つの段階は規格の箇条 6 、 8 、 9 、 10 に当たる



段階ごとの担当と記録

計画から改善までの段階ごとに、担当と残す記録を決める

4 つの段階を 5 つの役割が担当する

段階	やること	担当	残す記録	箇条
計画	リスク対応を決める	情報セキュリティ責任者	リスク対応計画、適用宣言書	6
運用	3 つの場面で実行する	利用者、基盤の担当	申請、点検、事故の報告	8
評価	記録と内部監査で確かめる	内部監査の担当	内部監査の報告	9
改善	結果を見直して計画に戻す	経営層	マネジメントレビューの記録	10

リスク対応の選択

計画では、 10 のリスクごとにリスク対応と担当を決める

10 のうち 6 つは低減し、 4 つは回避する [3]

リスク	4 つの管理策の有効性	選択肢	追加のリスク対応	担当
ASI01 目標の乗っ取り	⊖ **低減できない**	低減	信頼できるファイルだけ持ち込む	利用者
ASI02 ツールの悪用	✓ **低減できる**	低減	秘密は絞り、データは控えを取る	基盤の担当
ASI03 身元と権限の悪用	✓ **低減できる**	回避	認証を渡さない	基盤の担当
ASI04 供給網のぜい弱性	✓ **低減できる**	低減	確かめた部品だけ取り込む	基盤の担当
ASI05 想定外のコード実行	✓ **低減できる**	低減	成果物はコンテナの中で動かす	利用者
ASI06 記憶と文脈の汚染	⊖ **低減できない**	回避	履歴を持ち越さない	利用者
ASI07 安全でないエージェント間通信	⊖ **低減できない**	回避	連携させない	基盤の担当
ASI08 連鎖的な障害	✓ **低減できる**	回避	後工程につながない	利用者
ASI09 人の信頼の悪用	⊖ **低減できない**	低減	確かめてから承認する	利用者
ASI10 暴走エージェント	✓ **低減できる**	低減	人が見ている間だけ動かす	基盤の担当

基盤の担当が強制する設定

担当のうち基盤の担当は、 5 つのリスク対応を設定で強制する

5 つのリスクと 3 つのぜい弱性に、設定で強制する対応がある [4]

対象	基盤の担当が強制する設定	設定の場所
ASI02 ツールの悪用	秘密は基盤から配る	コンテナの設定
ASI03 身元と権限の悪用	Git の認証を配らない	コンテナの設定
ASI04 供給網のぜい弱性	通信の許可先を社内の部品置き場にする	コンテナの設定
ASI07 安全でないエージェント間通信	連携先を許可したものに限る	Claude Code の管理設定
ASI10 暴走エージェント	許可確認を省く動かし方を禁じる	Claude Code の管理設定
持ち出しの経路（ SSH の宛先が無制限）	SSH の宛先を許可先だけにする	コンテナの設定
設定のぜい弱性（版が未固定）	版を固定し、自動更新を止める	コンテナの設定
監視のぜい弱性（記録がない）	履歴の保存日数を決める	Claude Code の管理設定

附属書 A との比較

リスク対応に要る管理策は、附属書 A と見比べて見落としを確かめる

附属書 A の 93 のうち 14 と見比べ、見落としが 1 つあった [5]

決めた管理策	見比べた附属書 A の管理策	結果
通信の許可リスト	8.20 ネットワークセキュリティ、 8.22 ネットワークの分離、 8.23 ウェブフィルタリング	✓ 重なる
非 root 実行	8.2 特権アクセス権	✓ 重なる
ファイルの隔離	8.3 情報へのアクセス制限	✓ 重なる
起動時の検証	8.9 構成管理	✓ 重なる
認証を渡さない決まり	5.17 認証情報	✓ 重なる
部品を確かめる決まり	5.21 ICT サプライチェーンにおける情報セキュリティの管理	✓ 重なる
10 の決まりを定めること	5.10 情報およびその他の関連資産の利用の許容範囲	✓ 重なる
利用開始のときの教育	6.3 情報セキュリティの意識向上、教育および訓練	✓ 重なる
事故の報告と対応	6.8 情報セキュリティ事象の報告、 5.26 情報セキュリティインシデントへの対応	✓ 重なる
ローカルの履歴を記録に残す	8.15 ログ取得	✓ 重なる
当たる管理策がない	8.16 監視活動	⚠ 見落とし

残留リスク

管理策を講じた後の残留リスクは、リスク所有者が受容を承認する

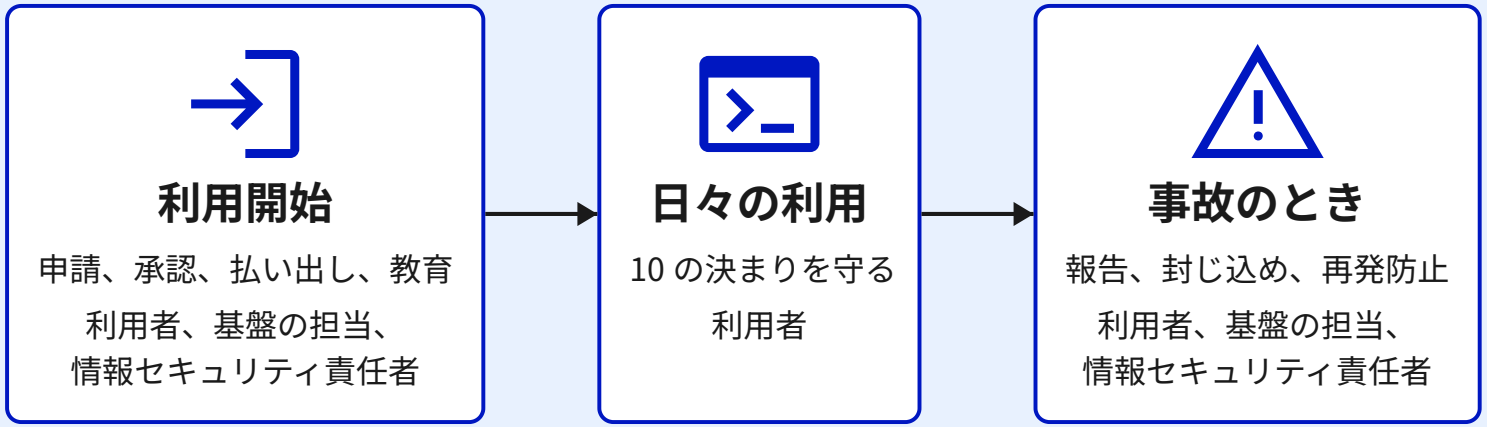
6 種類の残留リスクは、 3 つの条件を守る前提で受容する [6]

残留リスク	数	中身	受容の条件
判断に関わるリスク	4 つ	4 つの管理策が効かず、決まりに頼る	信頼できるファイルだけ持ち込む
持ち出しの経路	3 つ	DNS 、許可先、ホスト側ネットワーク	ホストの秘密を持ち込まない
設定のぜい弱性	2 つ	許可 IP の固定、 IPv6	ホストの秘密を持ち込まない
ホスト側への波及	2 つ	作業フォルダ経由の実行、認証の引き継ぎ	信頼できるファイルだけ持ち込む
監視のぜい弱性	1 つ	監視がなく、記録は書き換えられる	Claude の動作を監視する
強制の抜け道	1 つ	設定を入れたイメージは差し替えられる	信頼できるファイルだけ持ち込む

運用の 3 つの場面

承認を得たら、利用開始、日々の利用、事故の 3 つの場面で運用する

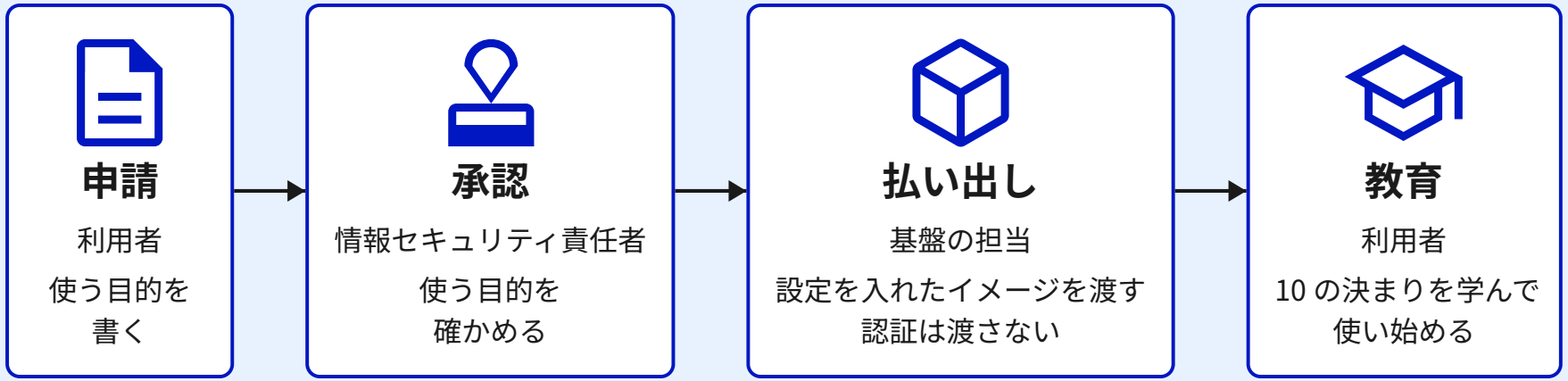
3 つの場面のどれにも利用者が関わる



利用開始の流れ

利用開始では、申請と承認を経て環境を払い出す

4 つの手順を 3 つの役割が分担する



日々の利用の決まり

払い出した環境では、 10 の決まりのうち 5 つを利用者が守る

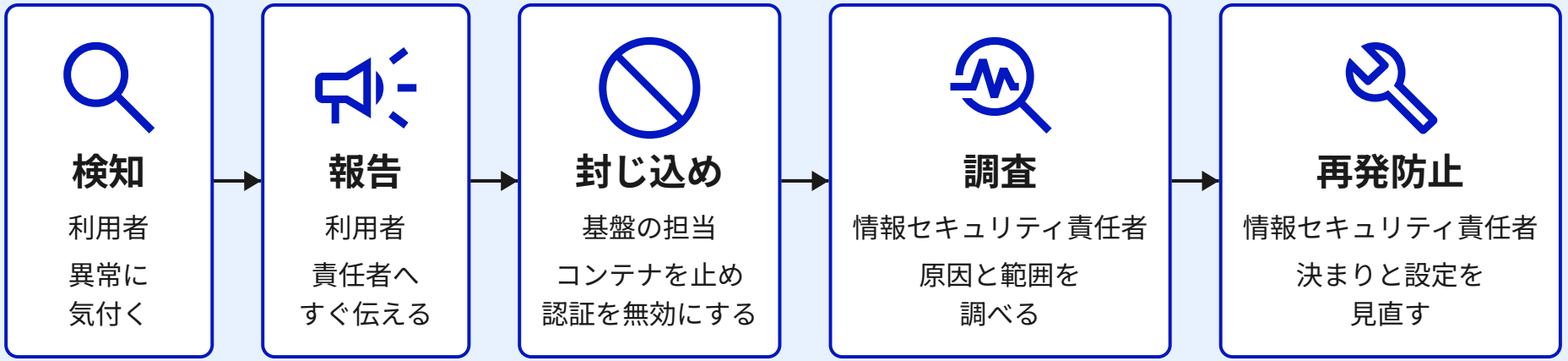
10 のうち 5 つは設定で強制し、 5 つは利用者が守る

リスク	決まり	守らせ方	残す記録
ASI01 目標の乗っ取り	信頼できるファイルだけ持ち込む	利用者が守る	自己点検の記録
ASI02 ツールの悪用	秘密は絞り、データは控えを取る	設定で強制	払い出しの記録
ASI03 身元と権限の悪用	認証を渡さない	設定で強制	払い出しの記録
ASI04 供給網のぜい弱性	確かめた部品だけ取り込む	設定で強制	払い出しの記録
ASI05 想定外のコード実行	成果物はコンテナの中で動かす	利用者が守る	自己点検の記録
ASI06 記憶と文脈の汚染	履歴を持ち越さない	利用者が守る	自己点検の記録
ASI07 安全でないエージェント間通信	連携させない	設定で強制	払い出しの記録
ASI08 連鎖的な障害	後工程につながない	利用者が守る	自己点検の記録
ASI09 人の信頼の悪用	確かめてから承認する	利用者が守る	自己点検の記録
ASI10 暴走エージェント	人が見ている間だけ動かす	設定で強制	払い出しの記録

事故のときの流れ

利用者は、事故に気付いたら報告し、封じ込めから再発防止へ進める

5 つの手順を 3 つの役割が分担する



残す記録

報告と日々の記録は、内部監査で決まりどおりかを評価する

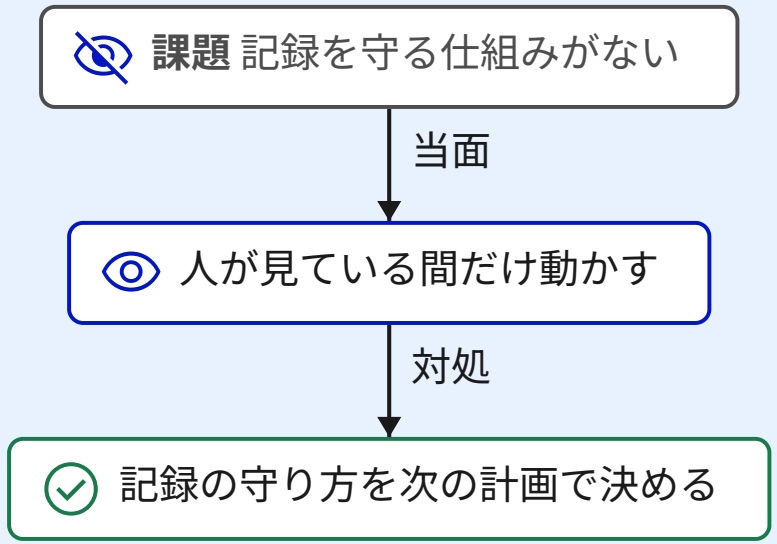
5 つの記録を 3 つの場面で作る

記録	作る人	場面	内部監査で確かめること
利用の申請	利用者	利用開始	使う目的が承認されているか
払い出しの記録	基盤の担当	利用開始	強制する設定を入れて渡しているか
自己点検の記録	利用者	日々の利用	利用者が守る 5 つを守っているか
ローカルの履歴	Claude Code	日々の利用	事故のときに動作をたどれるか
事故の報告	利用者	事故のとき	再発防止まで済んでいるか

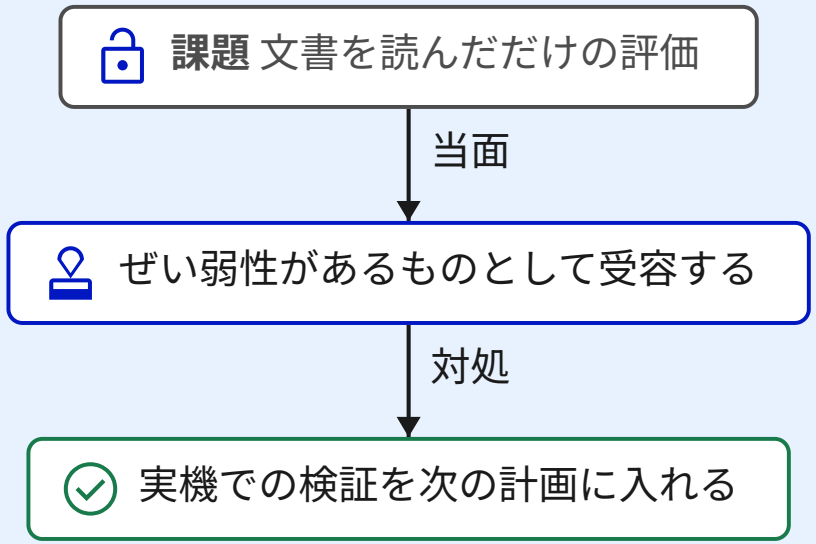
評価に残る課題

評価するための記録と検証には、まだ 2 つの課題がある

ローカルの履歴は利用者が書き換えられる



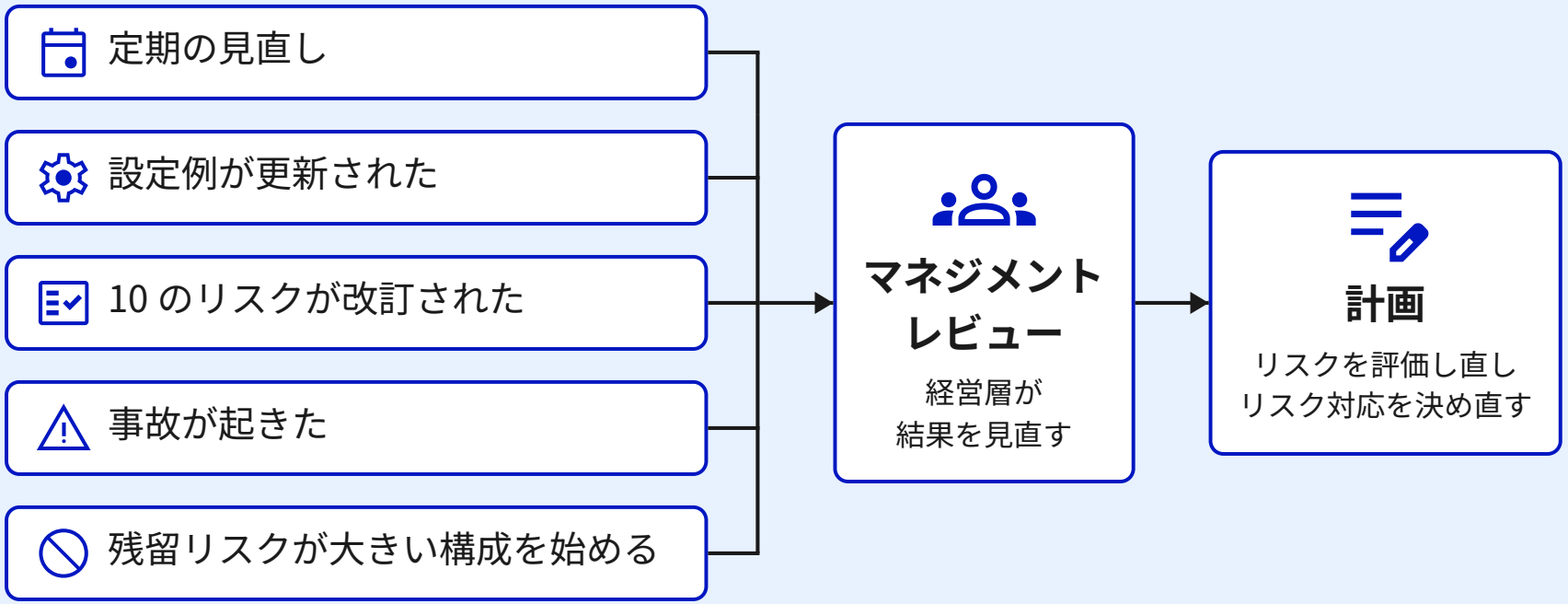
強制する設定とぜい弱性は実機で試していない



見直しのきっかけ

課題と評価の結果は、マネジメントレビューで見直して計画に戻す

見直しは定期のほか 4 つのきっかけで行う



ご承認いただきたい 3 つのこと

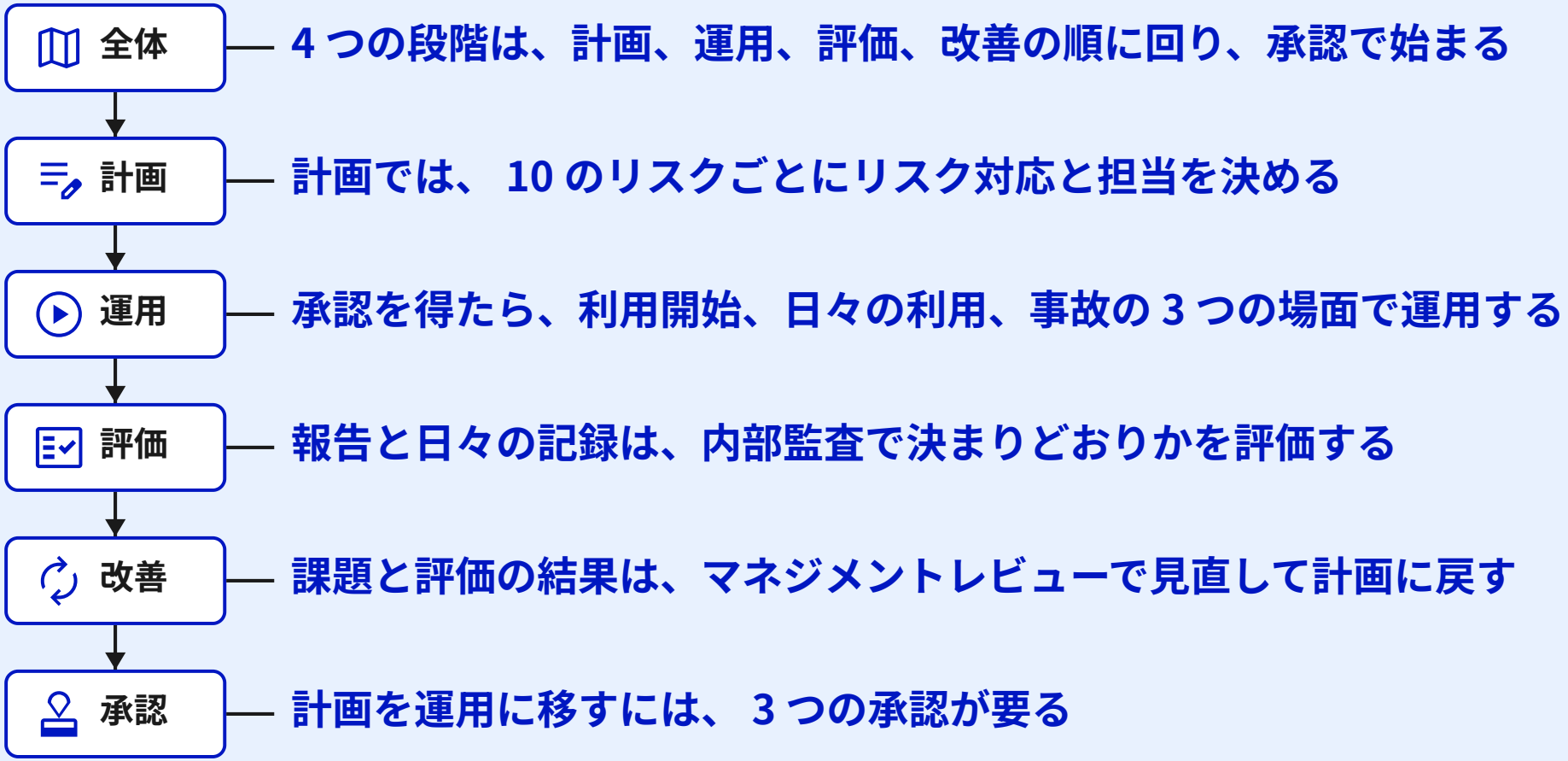
計画を運用に移すには、 3 つの承認が要る

3 つのうち 2 つはリスク所有者が承認する

承認すること	承認する人	残す記録	根拠のスライド
リスク対応の内容	リスク所有者	リスク対応計画	リスク対応の選択 附属書 A との比較
残留リスクの受容	リスク所有者	残留リスクの受容の記録	残留リスク
担当の割り当てと利用開始	情報セキュリティ責任者	利用の承認の記録	段階ごとの担当と記録 利用開始の流れ

まとめ

Dev Container は、 3 つの承認を得て ISMS の 4 つの段階で運用する



付録 1 Claude Code の管理設定

Claude Code の管理設定は、 1 つのファイルに書いてイメージに入れる

3 つの設定は /etc/claude-code/managed-settings.json に書く [7]

強制する設定	設定の名前	値
許可確認を省く動かし方を禁じる	permissions.disableBypassPermissionsMode	"disable"
連携先を許可したものに限る	allowedMcpServers	許可する連携先の一覧
連携先を許可したものに限る	allowManagedMcpServersOnly	true
履歴の保存日数を決める	cleanupPeriodDays	日数（既定は 30 、最小は 1 ）

付録 2 コンテナの設定

コンテナの設定は、設定例の 2 つのファイルを書き換える

5 つの設定を 2 つのファイルで強制する [8]

強制する設定	ファイル	書き換える内容
版を固定し、自動更新を止める	devcontainer.json	CLAUDE_CODE_VERSION を latest から決めた版にする
版を固定し、自動更新を止める	devcontainer.json	containerEnv に DISABLE_AUTOUPDATER を 1 で足す
通信の許可先を社内の部品置き場にする	init-firewall.sh	許可先の registry.npmjs.org を社内の部品置き場に替える
SSH の宛先を許可先だけにする	init-firewall.sh	22 番ポートを宛先を問わず許可する 2 行を消す
秘密は基盤から配る	devcontainer.json	containerEnv で渡し、 mounts は足さない
Git の認証を配らない	devcontainer.json	containerEnv と mounts に Git の認証を入れない

参考文献（ 1/2 ）

1. （氏名） , "Claude Code の Dev Container で低減できるリスク " (2026)
   10 のリスク、 4 つの管理策、 10 のぜい弱性は、この資料による
2. 一般財団法人日本情報経済社会推進協会 , "ISMS ユーザーズガイド " JIP-ISMS111-4.0 (2025);
   www.jipdec.or.jp/archives/publications/JIP-ISMS111-4.0.pdf
3. 独立行政法人情報処理推進機構 , " 中小企業の情報セキュリティ対策ガイドライン 第 3.1 版
   リスク分析シート " (2024);
   www.ipa.go.jp/security/sme/f55m8k000000587z-att/outline_guidance_risk.pdf
4. Anthropic, Development containers, Claude Code Docs (2026);
   code.claude.com/docs/en/devcontainer
5. ISMS Guide, 管理策一覧（ Annex A ） (2026);
   isms-guide.com/controls/

参考文献（ 2/2 ）

6. 日本産業標準調査会 , "JIS Q 27001:2014 情報セキュリティマネジメントシステム―要求事項 " （現行は 2025 年版） (2014); kikakurui.com/q/Q27001-2014-01.html

7. Anthropic, Control MCP server access for your organization; Explore the .claude directory, Claude Code Docs (2026); code.claude.com/docs/en/managed-mcp code.claude.com/docs/en/claude-directory

8. Anthropic, claude-code: .devcontainer (2026); github.com/anthropics/claude-code/tree/main/.devcontainer